

Purview Data Governance and Copilot Security

Microsoft 365 E5 Lab — Hebshi Inc (Simulated Environment)

Hussein Al-Hebshi

Security Engineer | Microsoft 365 | Information Protection

Self-directed lab modeled on enterprise deployment scenarios | 2025-2026

1. Overview

This lab builds a complete data governance and AI security environment on a Microsoft 365 E5 tenant. The setup simulates a mid-size organization called Hebshi Inc with five business departments: HR, Finance, Legal, Executive, and IT.

The main question this lab answers is: how do you make Copilot safe to deploy? Copilot reads whatever the signed-in user can access. If files are unlabeled, overshared, or unencrypted, Copilot will surface them to the wrong people. This lab fixes that before Copilot is turned on.

The work covers the full Purview stack: sensitivity labels, auto-labeling, DLP across every data channel, insider risk, eDiscovery, records management, and AI governance. It also includes a Power Automate flow that uses Azure OpenAI to recommend labels for unlabeled files and routes high-sensitivity decisions to the file owner for approval.

Environment

Component	Detail
Tenant	simbaloa.onmicrosoft.com (E5)
Identity	Entra ID with hybrid sync (Entra Connect, Password Hash Sync)
On-premises	Windows Server 2022 AD DS (simbaloa.local / SIMBA-DC01)
SharePoint sites	Hebshi-HR, Hebshi-Finance, Hebshi-Legal, Hebshi-Executive, Hebshi-IT, Hebshi-Operations
Purview	Information Protection, DLP, IRM, eDiscovery, Records Management, Compliance Manager, DSPM for AI
AI	Microsoft 365 Copilot, Azure OpenAI (socai-lab.openai.azure.com)
Automation	Power Automate, Azure Key Vault, Microsoft Graph API
Add-ons	SharePoint Advanced Management

Product name ↑	Assigned licenses	Purchased quantity	Available licenses	Subscription status	Renewal or expiration...	Billing profile	Purchase channel	Product type	Price
☐  Agent 365	10	25	15	Active	Renews on 7/29/2026 with 1 paid license	hebshi	Commercial direct	License-based	Trial
☐  Enterprise Mobility + Security E5	11	25	14	Active	7/26/2026	hebshi	Commercial direct	License-based	Trial
☐  Microsoft Copilot Studio	Not available	25	Not available	Active	7/13/2026	hebshi	Commercial direct	License-based	Trial
☐  Microsoft Defender Suite	11	25	14	Active	7/26/2026	hebshi	Commercial direct	License-based	Trial
☐  Microsoft Entra ID Free Microsoft Entra ID Free	Not available	1	Not available	Active	Not available	hebshi	Commercial direct	License-based	Paid
☐  Microsoft Entra ID Governance	10	25	15	Active	Renews on 7/29/2026 with 1 paid license	hebshi	Commercial direct	License-based	Trial
☐  Microsoft Purview Suite	11	25	14	Active	7/26/2026	hebshi	Commercial direct	License-based	Trial
☐ Office 365 E5	11	25	14	Active	7/26/2026	hebshi	Commercial direct	License-based	Trial
☐  Power Apps Premium	11	25	14	Active	6/27/2026	hebshi	Commercial direct	License-based	Trial
☐  Power Automate Premium	18	25	7	Active	Renews on 8/4/2026 with 1 paid license	hebshi	Commercial direct	License-based	Trial
☐  SharePoint advanced management plan 1	18	25	7	Active	Renews on 8/2/2026 with 1 paid license	hebshi	Commercial direct	License-based	

2. Test Data Setup

Six SharePoint sites were created to simulate a real company. Each site holds files with realistic sensitive content: Canadian Social Insurance Numbers (SINs), bank account numbers, passport numbers, salary data, and legal records. The mix of file types and sensitivity levels is intentional so DLP, auto-labeling, and Copilot controls have real content to work with.

Site	Content	Sensitive data types
Hebshi-HR	Employee records, salary reviews, performance reviews, disciplinary files	SINs, DOB, salary amounts, addresses
Hebshi-Finance	Budget plans, bank account register, AP transactions	Bank account numbers, financial totals
Hebshi-Legal	Legal exposure memos, contract logs, settlement drafts	SINs, bank accounts, litigation amounts
Hebshi-Executive	Board minutes, succession planning, compensation data	SINs (CEO/CFO/CTO), M&A details
Hebshi-IT	Vulnerability reports, privileged account inventory	Service accounts, CVE details
Hebshi-Operations	Staff directory, supply chain reports, budget files	SINs, bank accounts

Files were created as proper Office documents (.docx, .xlsx) so the Purview content scanner can read them. Plain text and CSV files were also added to demonstrate which file types the scanner does and does not classify.

SharePoint
Search this library

CH
Hebshi-HR

Home
Conversations
Documents
Notebook
Pages
Site contents
Recycle bin
Edit
Return to classic SharePoint

Documents
Add shortcut to OneDrive
Forms
Edit in grid view

All Documents

Name	Modified	Modified By	Sensitivity
Disciplinary-File-Bergeron.txt	5 days ago	Hussein	
Employee-Records.docx	6 days ago	Hussein	Highly Confidential \ HR Only
HR-Disciplinary-Bergeron.docx	4 days ago	Hussein	General \ All Employees (unrestricted)
HR-Employee-Master.csv	5 days ago	Hussein	
HR-Employee-Master.xlsx	4 days ago	Hussein	Highly Confidential \ HR Only
HR-Employee-Master1.xlsx	3 days ago	Hussein	Highly Confidential \ HR Only
HR-Employee-Master2.xlsx	2 days ago	Hussein	Highly Confidential \ HR Only
HR-Employee-Master3.xlsx	2 days ago	Hussein	Highly Confidential \ HR Only
HR-Employee-Records.docx	4 days ago	Hussein	Highly Confidential \ HR Only
HR-Performance-Reviews.docx	4 days ago	Hussein	Highly Confidential \ HR Only
HR-Salary-Review.xlsx	4 days ago	Hussein	Highly Confidential \ HR Only
Performance-Reviews-Q1-2026.txt	5 days ago	Hussein	

3. Sensitivity Labels

A five-tier label taxonomy was built and published to all users. The two top tiers carry encryption. The lower tiers are used for marking and visibility only. Applying encryption to everything would create too much friction in day-to-day work, so encryption is reserved for content that genuinely needs it.

Label	Encryption	Rights	Use case
Personal	None	N/A	Non-business content
Public	None	N/A	Approved for public release
General	None	N/A	Standard internal business content
Confidential / Finance	Yes	Editor (co-author)	Financial records, bank data, forecasts
Highly Confidential / HR Only	Yes	Viewer (read only)	HR records, SINS, salary data, disciplinary files

Two additional sublabels were created using PowerShell to automate the build and keep a clear record of the configuration:

```
New-Label -DisplayName "HR Only" -Name "HROnly" -Comment "Highly confidential HR data." -Tooltip "Do not share outside HR." -ParentId "defa4170-0d19-0005-0009-bc88714345d2" -EncryptionEnabled $true -EncryptionProtectionType "Template" -EncryptionRightsDefinitions "Hussein@simbaloa.onmicrosoft.com:VIEWER" -EncryptionOfflineAccessDays -1
```

The label policy enforces mandatory labeling on all documents and emails. Users must provide a reason before they can remove a label or lower the classification. This creates an audit trail and discourages casual downgrading.

Purview Information Protection showing the full label taxonomy

Microsoft Purview

Search for solutions, users, articles, and more

Information Protection

- Overview
- Reports
- Pay-as-you-go usage report
- Recommendations
- Sensitivity labels**
- Policies
- Classifiers
- Explorers
- Diagnostics

Related solutions

- Data Security Investigations
- Data Lifecycle Management
- Data Loss Prevention

Sensitivity labels

You can now create sensitivity labels with privacy and access control settings for Teams, SharePoint sites, and Microsoft 365 Groups. To do this, you must first [complete these steps](#) to enable the feature.

Sensitivity labels are used to classify email messages, documents, sites, and more. When a label is applied (automatically or by the user), the content or site is protected based on the settings you add content marking, and control user access to specific sites. [Learn more about sensitivity labels](#)

Congrats... you've been migrated to the modern label scheme. [Learn more about the modern label scheme](#)

+ Create Publish labels Export Refresh

☐	Name	Priority	Scope	Created by	Last modified
☐	Personal	0	Files & other data assets, Email, ...	Microsoft Corporation	Mar 25, 2026 5:59:13 AM
☐	Public	1	Files & other data assets, Email, ...	Microsoft Corporation	Mar 25, 2026 5:59:18 AM
☐	General	2		Microsoft Corporation	Mar 25, 2026 5:59:22 AM
☐	Anyone (unrestricted) -old	3	Files & other data assets, Email, ...	Microsoft Corporation	Jun 1, 2026 10:47:19 PM
☐	All Employees (unrestricted)	4	Files & other data assets, Email, ...	Microsoft Corporation	Mar 25, 2026 5:59:24 AM
☐	Confidential	5		Microsoft Corporation	Mar 25, 2026 5:59:29 AM
☐	Anyone (unrestricted)	6	Files & other data assets, Email, ...	Microsoft Corporation	Mar 25, 2026 5:59:28 AM
☐	Trusted People	7	Files & other data assets, Email, ...	Microsoft Corporation	Jun 1, 2026 11:46:18 PM
☐	Finance	8	Files & other data assets, Email, ...	Hussein	Jun 2, 2026 12:01:53 AM
☐	Highly Confidential	9		Microsoft Corporation	Jun 1, 2026 11:44:23 PM
☐	All Employees	10	Files & other data assets, Email, ...	Microsoft Corporation	Jun 1, 2026 11:44:23 PM
☐	Specified People	11	Files & other data assets, Email, ...	Microsoft Corporation	Jun 1, 2026 11:46:21 PM
☐	HR Only	12	Files & other data assets, Email, ...	Hussein	Jun 2, 2026 12:01:52 AM

document showing the Highly Confidential HR Only label applied

HR-Employee-Master

Search for tools, help, and more (Alt + Q)

File Home Insert Share Page Layout Formulas Data Review View Automate Help Draw

Clipboard Font Paragraph Alignment Number Styles Cells Editing

Comments Catch Up Editing

Sensitivity labels: Personal, Public, General, Confidential, **Highly Confidential**, All Employees, Specified People, HR Only

Employee ID	Full Name	SIN	Department	Salary	Manager	Start Date	Status
EMP001	James White	045-454-2	Engineering	110000	Sarah Chen	3/15/2019	Active
EMP002	Priya Sharma	502-000-1	Finance	94500	Marc Trem	7/1/2020	Active
EMP003	Lucas Ben	123-456-7	Marketing	87000	Sarah Chen	1/10/2021	Active
EMP004	Fatima Al	131-892-5	Operations	102000	Marc Trem	8/15/2019	Active
EMP005	Daniel Park	045-783-2	Engineering	125000	Sarah Chen	6/5/2017	Active
EMP006	Isabelle D	502-341-9	HR	91000	Julia Mart	3/1/2022	Active
EMP007	Michael T	123-789-4	Sales	88500	Julia Mart	9/15/2020	Active
EMP008	Aisha Moh	130-445-3	Finance	97000	Marc Trem	5/22/2019	Active

mandatory labeling enforcement message

Document

Search for tools, help, and more (Alt + Q)

File Home Insert Layout References Review View Help

Clipboard Font Paragraph Alignment Number Styles Cells Editing

Add sensitivity label Your organization requires you to label this document before editing.

4. Auto-labeling

Two auto-labeling policies were configured to classify files automatically based on content. No user action is needed. The scanner reads each file and applies the label when it finds a match.

Policy	Detects	Applies	Scope
AutoLabel-HROnly	Canada Social Insurance Number	Highly Confidential / HR Only	SharePoint, OneDrive
AutoLabel-Finance	Canada Bank Account Number	Confidential / Finance	SharePoint, OneDrive

Both policies were set to Enable mode directly rather than running simulation first. In a production environment you would run simulation for 1-2 weeks to validate match accuracy before enabling enforcement. Skipping simulation in a lab is acceptable because the tenant content is controlled and the risk of false positives is known.

The policies were configured with PowerShell:

```
New-AutoSensitivityLabelPolicy -Name "AutoLabel-HROnly" -ApplySensitivityLabel "HROnly" -SharePointLocation "All" -OneDriveLocation "All" -Mode "Enable"
New-AutoSensitivityLabelRule -Name "Detect-Canadian-SIN-SPO" -Policy "AutoLabel-HROnly" -ContentContainsSensitiveInformation @{"name"="Canada Social Insurance Number";"mincount"="1"} -Workload SharePoint
```

Key finding: the scanner only classifies Office format files (.docx, .xlsx, .pdf). Plain text and CSV files are detected as containing sensitive information but do not get labeled automatically. This is the exact gap that the AI Label Advisor in Section 11 was built to address. The scanner can identify that a file contains a SIN but cannot label a .csv or .txt file. The AI flow picks up where the scanner stops by using file name and site context to recommend labels for any unlabeled file type and routing the decision to the file owner.

Purview Activity Explorer showing 'Label applied by auto label policies



5. Data Loss Prevention

Five DLP policies cover every data channel through which sensitive content could leave the organization. Each policy targets a different vector and all generate high-severity incident reports so matches become actionable alerts.

Policy	Channel	Sensitive data covered	Action
Hebshi-CanadianPII-Protection	SharePoint, OneDrive	SIN, Passport	Block external access, notify owner
Hebshi-FinancialData-Protection	SharePoint, OneDrive	Bank account, Credit card, Passport	Block external access, notify owner
Hebshi-Email-PII-Protection	Exchange	SIN, Bank account, Passport	Block outbound to external recipients
Hebshi-Endpoint-PII-Protection	Managed devices	SIN, Bank account, Passport	Block print, clipboard, USB, screen capture, network share
Protect M365 Copilot interactions	Microsoft 365 Copilot	SIN, Bank account, Passport	Block Copilot from processing sensitive prompts

The endpoint DLP policy enforces restrictions on devices that are onboarded to Microsoft Defender for Endpoint and enrolled in Intune. Enforcement as Block rather than Audit depends entirely on the device being properly onboarded and the policy being correctly scoped. The Microsoft.GraphServices billing setup mentioned in Section 11 applies only to the automated label assignment API and has no bearing on endpoint DLP enforcement.

Purview Data Loss Prevention Policies

</

- + Choose different remote desktop restrictions

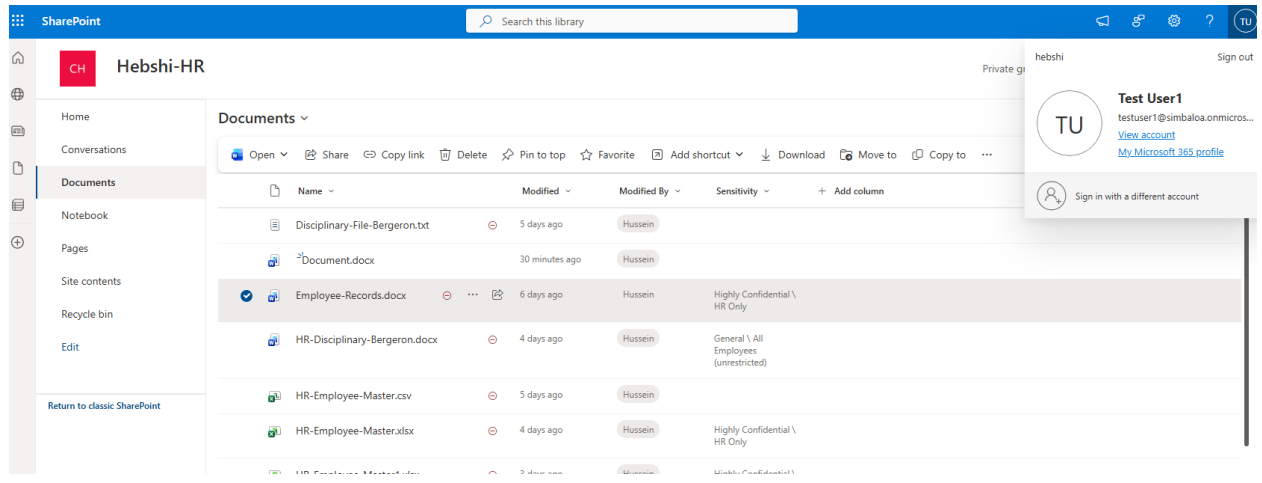
6. Data Security Failure Scenarios

Seven common data security failures were deliberately reproduced in the tenant to validate that the controls detect and address each one. This mirrors how a real pre-Copilot assessment works: identify the gaps first, then build the controls that close them.

Scenario	How it was reproduced	Control that addresses it
1. Oversharing	Documents library on Executive, Legal, and IT sites shared with 'Everyone except external users'	SharePoint Advanced Management oversharing report + remediation
2. Sensitive data in broadly shared locations	HR and financial files placed in sites with broad sharing permissions	DSPM for AI surfaces these in the data security posture dashboard
3. Unlabeled sensitive files	Files with SINS uploaded without labels applied	Auto-labeling policies detect and classify the content
4. Encrypted file blocking Copilot	HR Only label with encryption applied to employee records	Copilot cannot read encrypted content without decryption rights
5. Copilot processing a sensitive prompt	User asks Copilot to summarize file containing SINS	DLP for Copilot blocks the prompt from being processed
6. Risky AI interaction patterns	Repeated queries to Copilot targeting sensitive data	IRM policy (DSPM for AI) flags the activity
7. External sharing on a sensitive site	Finance site configured with ExternalUserAndGuestSharing	DLP external access block prevents sharing with guests

Oversharing condition that DSPM flags

Access denied when testuser1 who has SP site permissions tries to open the encrypted HR Only file



The screenshot shows the SharePoint interface for the 'Hebshi-HR' site. The 'Documents' library contains several files. The file 'Employee-Records.docx' is selected, and its details are shown, including a sensitivity label of 'Highly Confidential \ HR Only'. A user profile dropdown for 'Test User1' is visible in the top right corner.

Name	Modified	Modified By	Sensitivity
Disciplinary-File-Bergeron.txt	5 days ago	Hussein	
Document.docx	30 minutes ago	Hussein	
Employee-Records.docx	6 days ago	Hussein	Highly Confidential \ HR Only
HR-Disciplinary-Bergeron.docx	4 days ago	Hussein	General \ All Employees (unrestricted)
HR-Employee-Master.csv	5 days ago	Hussein	
HR-Employee-Master.xlsx	4 days ago	Hussein	Highly Confidential \ HR Only

simbaloa.sharepoint.com/sites/Contoso-HR/_layouts/15/Doc.aspx?sourcedoc=%7B0E7F8DC0-2066-43BF-B2A4-764B4D771DCE%7D&file=Employee-Records.docx&action=default&mobileredirect=true&CT=1780894281408&...

Sorry, you don't have permission to open this document

The document is protected by a rights management service, such as Azure Information Protection.

TECHNICAL DETAILS

[Troubleshoot issues with Microsoft SharePoint Foundation.](#)

Correlation ID: f07b1ba2-9049-d000-8670-da5bce8411da

Date and Time: 6/7/2026 9:51:21 PM

[GO BACK TO SITE](#)

7. Insider Risk Management

An Insider Risk Management policy was configured through the DSPM for AI recommendations blade. The policy monitors for risky AI interaction patterns including repeated attempts to extract sensitive data through Copilot, large volume downloads before a resignation, and unusual access to sensitive files outside normal working hours.

Policy	Template	Signals monitored	Status
DSPM for AI - Detect risky AI usage	AI usage risk	Copilot prompts referencing sensitive data, mass access to labeled files, unusual AI interaction patterns	Active

The policy was created through the DSPM recommendations blade rather than built manually. This is the realistic path an admin would take in production: run the Copilot readiness assessment, follow the recommendations, and let the tool configure the baseline controls.

Purview IRM AI Policy

The screenshot displays the Purview Insider Risk Management (IRM) interface. On the left is a navigation pane with options like Overview, Recommendations, Reports, Policies, and Users. The main area is titled 'Policies' and shows a list of policies. The 'DSPM for AI - Detect risky AI usage' policy is selected, and its configuration details are shown on the right.

Policies

- User Policies (selected) | Agent Policies
- Policy warnings: 0 | Policy recommendations: 1 | Healthy policies: 1
- Attention: You currently aren't assigned to a role group that allows you to view alerts. Consider assigning somebody to this role. [Learn which role groups are needed to review alerts](#)
- Review collection policies. Collection policies control what activities can be detected by device indicators. We recommend reviewing your org's collection policies to ensure they're set up to detect the... [collection policies](#)

Actions: + Create policy, Start scoring activity for users, Delete, Copy policy, Refresh, Download policy settings

Policy name	Status	Users in scope	Active alerts	Confirmed alerts
DSPM for AI - Detect risky AI usage	1 recommendation	0	0	0

DSPM for AI - Detect risky AI usage

Policy health last updated on: 2026-6-7 6:55 PM

Policy health | Policy settings (selected)

Policy template: Risky AI usage

User coverage: This policy is covering all active users in your org. Great job!

Coverage gauge: Low coverage (red), Medium coverage (orange), High coverage (green)

User scope: Include all users and groups (Recommended for best coverage)

Save changes

Content to prioritize: No content prioritized

Triggering thresholds: Built-in thresholds

Policy indicators:

- Browsed to generative AI websites
- Entering risky prompt in Copilot
- Receiving sensitive response from Copilot

Indicator thresholds: Built-in thresholds

Edit policy | Close

8. eDiscovery and Legal Hold

An eDiscovery case was created to simulate a real employment dispute scenario. The case is based on a fictional employee (Lucas Bergeron) whose disciplinary file, performance review, and HR record all exist in the Hebshi-HR and Hebshi-Legal sites. A legal hold was placed on both sites to preserve all content regardless of any deletion attempts.

Item	Detail
Case name	Bergeron-v-Hebshi-2026
Legal hold	Bergeron-Legal-Hold — applied to Hebshi-HR and Hebshi-Legal sites
Hold query	Bergeron OR SIN:123-456-789 OR lucas.bergeron
Content search	Bergeron-Content-Search — returned 9 items across HR, Legal, Executive sites
Status	Active

When a file under legal hold is deleted, SharePoint moves it to the Preservation Hold Library rather than permanently deleting it. The file disappears from the user's view but remains fully discoverable through eDiscovery. This behavior was validated by deleting a file and confirming it appeared in the Preservation Hold Library.

Purview eDiscovery case detail showing the Bergeron-v-Hebshi-2026 case

 eDiscovery

 Overview

 Cases

 Content Search

 Dashboards

Related solutions

 Audit

 Data Security Investigations

Cases > Bergeron-v-Hebshi-2026

Bergeron-v-Hebshi-2026

Employment dispute - Lucas Bergeron. Legal hold placed on HR and Legal sites pending litigation.

Hussein

Searches

Hold policies

Exports

Create holds to preserve content. Manage hold policies associated with custodians, create and manage additional locations, and optionally scope your hold policy. [Learn more about](#)

New policy

Export list

Refresh

1 item

Filter

Policy name	Modified	Status	Created by
☐ Bergeron-Legal-Hold	Jun 3, 2026 4:03 PM	On	Hussein

9. Records Management

Three retention policies and three record labels were configured to manage the lifecycle of content across the Hebshi sites. Records labels lock files so they cannot be modified or deleted during the retention period.

Policy / Label	Site	Retention	Action at end
Hebshi-HR-Retention + Hebshi-HR-Record	Hebshi-HR	7 years	Keep
Hebshi-Finance-Retention + Hebshi-Finance-Record	Hebshi-Finance	5 years	Keep
Hebshi-Legal-Retention + Hebshi-Legal-Record	Hebshi-Legal	10 years	Keep and Delete (with disposition review)

The Legal records label was configured with a disposition review. When the 10-year retention period ends, a reviewer (Hussein@simbaloa.onmicrosoft.com) is notified and must approve deletion before the file is permanently removed. This is required for regulated industries where records cannot be deleted without documented approval.

Records Management

Overview

File plan

Policies

Label policies

Policy lookup

Events

Disposition

Classifiers

Explorers

Label policies

Use label policies to publish or auto-apply labels. Auto-labeling policies apply labels to content matching conditions you define, while publishing label policies make labels available for users to manually apply in specific locations.

Label policies

Use label policies to publish or auto-apply labels. Auto-labeling policies apply labels to content matching conditions you define, while publishing label policies make labels available for users to manually apply in specific locations.

If your role group permissions are restricted to a specific set of users or groups, you'll only be able to manage policies for those users or groups. [Learn more about role group permissions.](#)

Publish labels

Auto-apply a label

Refresh

Name	Status	Type	Created by	Last modified by
☐ Hebshi-Publish-HR-Label	Enabled	Publish	Hussein	Hussein
☐ Hebshi-Publish-Finance-Label	Enabled	Publish	Hussein	Hussein
☐ Hebshi-Publish-Legal-Label	Enabled	Publish	Hussein	Hussein

10. Compliance Manager

Four compliance assessments were configured to map the technical controls built in this lab to regulatory frameworks. This translates individual configurations into a measurable compliance posture score.

Assessment	Framework	Relevance
Canada PIPEDA Assessment	Canada PIPEDA	Federal privacy law. The PII controls, DLP policies, and label encryption all map to PIPEDA requirements.
Hussein_CanadaHealth	Canada PHIPA (Ontario)	Ontario provincial health information protection law. Note: PHIPA applies at the provincial level. Federal health data privacy falls under PIPEDA. Both are included to reflect the dual regulatory landscape for organizations operating in Ontario.
AI Baseline Assessment	Microsoft AI Baseline	Microsoft's framework for securing AI deployments. Maps to Copilot governance controls.
Data Protection Baseline for Microsoft 365	Data Protection Baseline	Core M365 data protection control set. Covers DLP, labeling, access controls, and audit.

Improvement actions were completed for controls that were directly implemented in this lab including sensitivity label policies, DLP configuration, insider risk policies, eDiscovery setup, and audit log enablement. Completing these actions raises the compliance score and shows regulators that controls are actively managed.

Microsoft Purview Search for solutions, users, articles, and more

Assessments

Assessments help you implement data protection controls specified by compliance, security, privacy, and data protection standards, regulations, and laws. Assessments include actions that have been taken by Microsoft to protect your data, and they're completed when you take action to implement the controls included in the assessment. [Learn how to manage assessments](#)

Free regulation licenses used: 0/0 | Purchased regulation licenses used: 2/3

[View details](#)

+ Add assessment | Export actions | Update actions

4 items Search Group

Filters: Regulations: Any | Groups: Any | Service: Any | Role type: Any | Update status: Any | Filters

Assessment	Status	Progress	Your improvement ac...	Microsoft actions	Group	Service	Regulation	Role type
Canada PIPEDA Assessment	In progress	38%	6 of 60 completed	43 of 43 completed	Default Group	Microsoft 365	Canada PIPEDA	Admin
Hussein_CanadaHealth	In progress	52%	9 of 66 completed	68 of 68 completed	Default Group	Microsoft 365	Canada PHIPA	Admin
AI Baseline Assessment	In progress	60%	3 of 90 completed	96 of 96 completed	Default Group	Microsoft 365	AI Baseline	Admin
Data Protection Baseline for Microsoft 365	In progress	61%	52 of 483 completed	729 of 734 completed	Default Group	Microsoft 365	Data Protection Baseline	Admin

11. AI-Powered Label Advisor (Power Automate + Azure OpenAI)

One of the real gaps in Purview is that auto-labeling only works when content matches a predefined sensitive information type pattern. Files with ambiguous names or unstructured content that does not match a regex pattern go unclassified.

To address this, a Power Automate flow was built that runs daily, finds unlabeled files across all SharePoint sites, calls Azure OpenAI to recommend a sensitivity label based on the file name, file type, and site location, and then routes the recommendation for approval before applying the label via the Microsoft Graph API.

How the flow works

- Runs on a daily schedule at 8 AM.
- Connects to all SharePoint sites using the Microsoft Graph API and retrieves all files.
- For each unlabeled Office file (.docx, .xlsx), it calls Azure OpenAI with the file name, MIME type, site name, and site URL.
- OpenAI returns a recommended label, confidence level, and a plain-language reason.
- Files recommended as General or Public are auto-labeled immediately with no human approval.
- Files recommended as Confidential or Highly Confidential are added to a batch. After all sites are scanned, one approval email is sent listing all recommendations.
- The admin clicks Approve All or Reject All. If approved, the flow applies all labels via the Graph API assignSensitivityLabel endpoint.
- A daily summary email confirms what was labeled and what is pending.

Design decisions

- **No file content sent to OpenAI.** The model makes recommendations based on metadata only: file name, type, and site. Azure OpenAI is a private deployment within your own Azure subscription. Data sent to Azure OpenAI does not leave your Microsoft tenant boundary and is never used by Microsoft to train shared models. Even so, sending only metadata rather than raw file content is the right design because it is simpler, faster, and removes any question about what the model receives.
- **Batch approval instead of per-file approval.** Sending one email per file creates an unmanageable approval queue for large tenants. The batch approach sends one email per daily run, making it practical for real-world use.
- **Metered Graph API.** The assignSensitivityLabel endpoint is a metered Microsoft Graph API that costs \$0.00185 USD per call. The PnP-Lab app registration was linked to the Azure subscription using the Microsoft.GraphServices resource provider to enable billing. For a tenant with 100 files labeled per day, the cost is under \$0.20 per day.

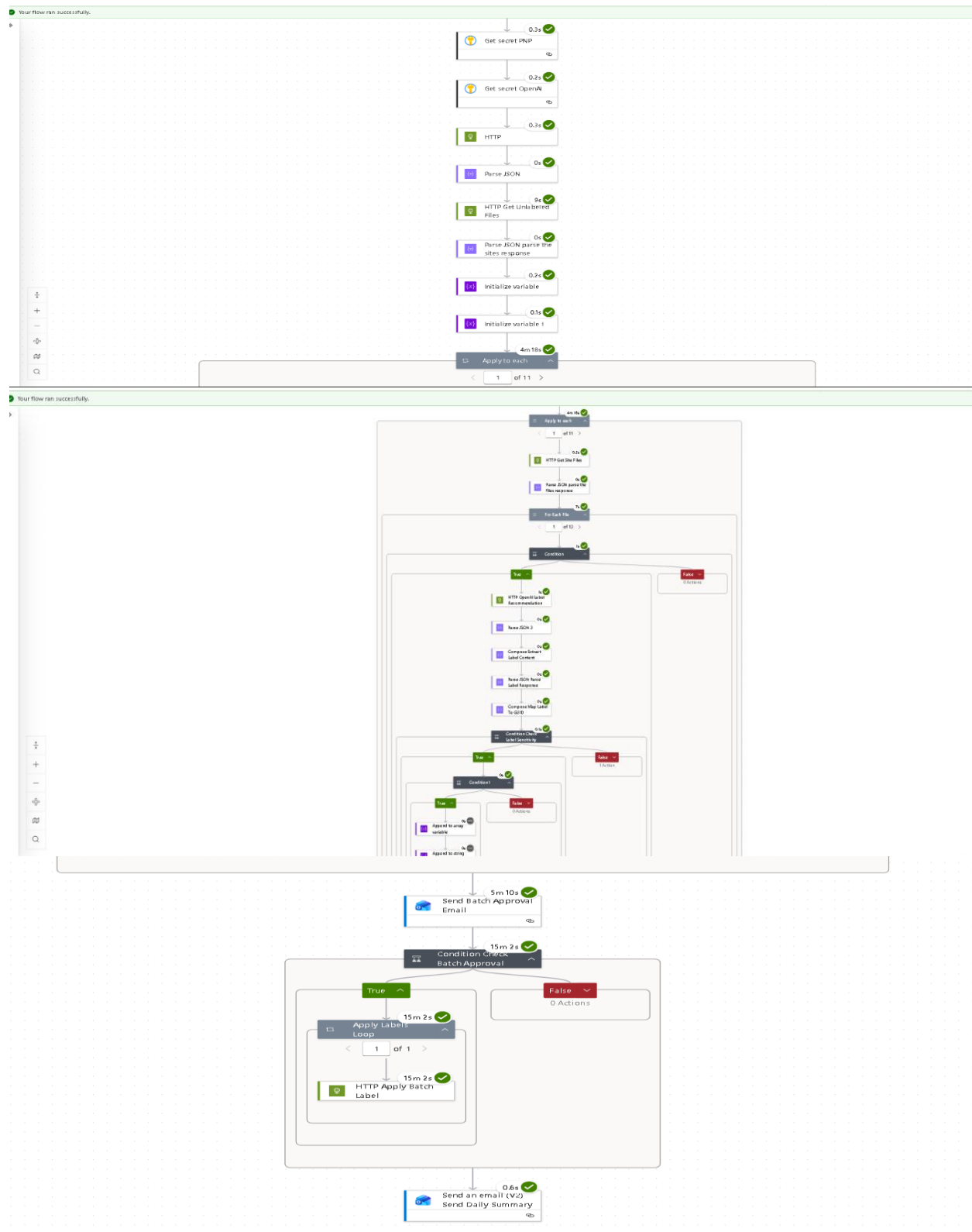
- **Secrets stored in Azure Key Vault.** The app client secret and Azure OpenAI API key are retrieved from Key Vault at runtime. They are never hardcoded in the flow.

Prompt design

The OpenAI system prompt includes explicit site-based rules to reduce ambiguity. Files in the HR site default to Highly Confidential HR Only. Files in the Finance site default to Confidential Finance. This makes the recommendations deterministic for known site structures while still allowing the model to use file name signals for edge cases.

Validated result

The flow was tested against an unlabeled file named 'Hussein SIN.docx' in the Hebshi-Operations site. OpenAI recommended Highly Confidential HR Only with High confidence. The reason given was: 'File name contains SIN which is sensitive HR-related information.' After approval, the label was applied successfully via the Graph API and the file showed the HR Only label in SharePoint.



HO

Hebshi-Operations

Home

Notebook

Documents

Pages

Site contents

Recycle bin

Edit

turn to classic SharePoint

Documents

All Documents

Name

Modified

Modified By

Add column

Document.docx

41 minutes ago

Hussein

Hussein SIN.docx

39 minutes ago

Hussein

Operations-Budget-2026.xlsx

42 minutes ago

Hussein

Operations-Staff-Directory.docx

10 hours ago

Hussein

Operations-Supply-Chain.docx

10 hours ago

Hussein

Today

Hussein

Action Required: Sensitivity Label Approval - Daily Run

4:16 PM

Request for your input

Hussein

Daily Purview AI Label Ad...

3:02 PM

Purview AI Label Advisor Daily Run ...

Hussein

Action Required: Sensitivity Label Approval - Daily Run

3:01 PM

Request for your input

Hussein

Daily Purview AI Label Ad...

3:02 PM

Purview AI Label Advisor Daily Run ...

Hussein

Action Required: Sensitivity Label Approval - Daily Run

11:54 AM

Request for your input

Hussein

Daily Purview AI Label Ad...

6:27 AM

Purview AI Label Advisor Daily Run ...

Hussein

Action Required: Sensitivity Label Approval - Daily Run

6:27 AM

Request for your input

Hussein

Daily Purview AI Label Ad...

6:12 AM

Purview AI Label Advisor Daily Run ...

Hussein

Action Required: Sensitivity Label Approval - Daily Run

6:11 AM

Request for your input

Hussein

Action Required: Sensitivity Label Approval - Daily Run

4:56 AM

Request for your input

Hussein

Action Required: Sensitivity Label Approval - Daily Run

Summarize this email

Request for your input

The following files have been analyzed and require your approval: File: [{"odata.etag": "\"[9B159697-A983-42A0-9758-B8A60C31C015]_2\"", "id": "015DRAJEXSYGZKXASJUBB/JWFYUGDDQAV", "name": "Hussein SIN.docx", "file": {"fileExtension": ".docx", "hashes": {"quickxorHash": "qOp4U66bIE9/+xFlaDf5OEQkgw="}, "mimeType": "application/vnd.openxmlformats-officedocument.wordprocessingml.document"}, "sensitivityLabel": {"displayName": "id", "id": "id", "protectionEnabled": false}}] Site: [{"id": "simbalooa.sharepoint.com,3b3fb77e-4a71-4081-9088-1c1785c30544,c880d07e-4b48-4ec5-90fd-96d2cb8c36e2", "name": "hebschi-operations", "webUrl": "https://simbalooa.sharepoint.com/sites/hebschi-operations"}] Recommended Label: Highly Confidential/HR Only Confidence: High Reason: File name contains 'SIN' which is sensitive HR-related information, defaulting to Highly Confidential/HR Only despite site not Indicating sensitivity. --- Please approve or reject all recommendations above.

Select one of the options below to respond

Approve All Reject All

Message sent via Microsoft Power Automate, enabling you to create automated workflows between your favorite apps and services.
© Microsoft Corporation 2026

Hussein

To: Hussein

Retention: Retention_7years_AllData (7 years) Expires: Sat 2033-06-04 4:16 PM

Action complete

Thank you!

Your response 'Approve All' has been successfully registered.

Reply Forward

Hussein SIN

Search for tools, help, and more (Alt + Q)

Home Insert Layout References Review View Help

Normal No Spacing Heading 1

Find Dictate

Sensitivity Editor Add ins

Personal

Public

General

Confidential

Highly Confidential

All Employees

Specified People

HR Only

CONFIDENTIAL

Operations Staff Directory

Employee: Ahmed Hassan

Social Insurance Number: 046-891-234

Role: Operations Manager

Salary: 95000

Employee: Marie Leclerc

Social Insurance Number: 527-234-891

Role: Logistics Coordinator

Salary: 72000

12. Microsoft 365 Copilot Security

This section covers the Copilot-specific controls. These build on everything configured above. The DLP policies, sensitivity labels, and DSPM assessment are all prerequisites for Copilot deployment.

Pre-deployment assessment

Before enabling Copilot, the DSPM for AI dashboard was used to assess whether the tenant data was ready. The assessment surfaces three categories of risk:

- Unlabeled files that Copilot could surface without any access control.
- Overshared sites where Copilot could reach content that should be restricted.
- Sites with external sharing enabled that could expose sensitive data through Copilot responses.

The oversharing assessment in SharePoint Advanced Management was also run to identify sites shared with 'Everyone except external users.' These sites were flagged as high risk before Copilot was enabled.

Copilot DLP controls

Two Copilot-specific DLP policies were configured:

- A SIT-based policy that blocks Copilot from processing any prompt or file containing a Canadian SIN, bank account number, or passport number.
- A label-based policy created from the DSPM remediation recommendations that restricts Copilot access to files carrying the Confidential and Highly Confidential labels.

Together these policies mean Copilot cannot summarize, explain, or reference any file that contains regulated Canadian data, whether the block is triggered by content pattern matching or by the sensitivity label on the file

Live test results

With a Copilot license assigned, the following tests were run:

Test	File	Expected result	Actual result
Ask Copilot to summarize encrypted HR file	HR-Employee-Records.docx (HR Only label, encryption)	Blocked — encryption prevents access	Blocked
Ask Copilot to summarize file with SIN	Operations Staff Directory.docx	DLP blocks the prompt	Blocked

Copilot blocked response when asked to summarize the encrypted file

Summary of HR-Employee-Records Doc

Work Web

Summarize the file Operations-Staff-Directory.docx from the Hebshi-Operations site

Copilot

I found 1 file result related to your request in the Hebshi-Operations site, but I'm unable to access or summarize its contents due to organizational security restrictions.

File located

- Name: **Operations-Staff-Directory**
- Authors: Test User1, Hussein
- Last modified: last Saturday
- Status: **Content blocked** — "Can't provide more information in accordance with your Organization's security policies"

Why a summary isn't available

Message Copilot

AI-generated content may be incorrect

Name	Modified	Modified By	Sensitivity
Document.docx	Yesterday at 2:52 PM	Hussein	Highly Confidential \ HR Only
Hussein SIN.docx	2 days ago	Hussein	Highly Confidential \ HR Only
Operations-Budget-2026.xlsx	2 days ago	Hussein	General \ All Employees (unrestricted)
Operations-Staff-Directory.docx	2 days ago	Hussein	General \ All Employees (unrestricted)
Operations-Supply-Chain.docx	2 days ago	Hussein	General \ All Employees (unrestricted)

Copilot blocked response by DLP blocks the prompt

Hebshi-Executive - Documents

Search this library

HE Hebshi-Executive

Not following Site access

Documents

Open Share Copy link Copilot Delete 1 selected Details

Name	Sensitivity	Add column
Board-Minutes-March-2026.txt		
Board-Strategy-Restricted.docx	Highly Confidential \ Highly Confidential - Hazz Only	
Executive-Board-Briefing-Q2.txt		
Executive-Board-Minutes.docx	General \ All Employees (unrestricted)	
Project-Falcon-Workforce.txt		
Project-Phoenix-Restricted.docx	Highly Confidential \ Highly Confidential - Hazz Only	
Succession-Planning-2026.txt		
test.txt		

Copilot

Coding and executing

I located the file "Board-Strategy-Restricted.docx" in your Contoso-Executive SharePoint library, but I don't currently have access to its contents, so I'm unable to extract or summarize the document itself.

What I can confirm

- The file exists in your environment: **Board-Strategy-Restricted.docx**
- However, the content is **not retrievable in this session**, which typically indicates:
 - Restricted or sensitivity-labeled document
 - Permissions that prevent content access (even if metadata is visible)

Why this happens

Documents labeled "Restricted" are commonly configured to:

- Block programmatic access to content
- Limit visibility to a specific executive group
- Prevent preview or extraction unless opened with proper credentials

How to get a summary quickly

To generate an accurate summary, you can:

1. Open the file from SharePoint
2. Copy and paste the text (or key sections) here, or
3. Share a direct access link with view permissions

Message Copilot

AI-generated content may be incorrect

13. Defender XDR and Sentinel Integration

DLP alerts and IRM signals from Purview flow into Microsoft Defender XDR automatically with E5 licensing. The Microsoft Defender XDR data connector in Sentinel was enabled so that Purview DLP incidents also appear in Sentinel for correlation with endpoint and identity signals.

Data source	Alert type	Flows to
Purview DLP	Policy match on sensitive data in SharePoint, email, or endpoint	Defender XDR incidents, Sentinel via Defender XDR connector
Purview IRM	Risky AI usage, unusual file access patterns	Defender XDR incidents
Purview Information Protection	Label activity, sensitivity events	Sentinel via Information Protection connector
Entra ID Protection	Risky sign-in, compromised credential signals	Defender XDR incidents, Sentinel

Once a DLP policy match occurs, the alert appears in the Defender XDR alerts queue and is automatically linked into an incident if related signals are present from the same user or device. Security teams can investigate the full context: what file was accessed, what label it carried, what the user did next, and whether any endpoint activity is correlated.

DLP alerts in Sentinel can be queried using KQL:

```
AlertInfo | where ServiceSource == "Microsoft Purview Data Loss Prevention" | project TimeGenerated, Title, Severity, Entities | order by TimeGenerated desc
```

14. Controls Summary

The table below maps every control built in this lab to the capability it demonstrates and the job role it is most relevant for.

Control	What it does	Relevant for
Sensitivity label taxonomy	Classifies and marks all content across M365	Purview Specialist, Data Governance
Label encryption (HR Only, Finance)	Blocks unauthorized users from opening files regardless of SharePoint permissions	Information Protection, Zero Trust
Mandatory labeling policy	Forces users to label all documents and emails	Compliance, Governance
Auto-labeling (SIN, Bank Account)	Labels files automatically based on content without user action	Purview Specialist, Automation
DLP (5 policies)	Blocks sensitive data from leaving via SharePoint, email, endpoint, or Copilot	DLP, Compliance, SecOps
Oversharing configuration + remediation	Identifies and fixes sites that are too broadly shared before Copilot is enabled	Copilot readiness, Governance
Insider Risk Management	Detects risky AI usage and unusual file access patterns	SecOps, Insider Threat
eDiscovery + legal hold	Preserves content for litigation and investigation	Compliance, Legal
Records management	Enforces retention periods and controls deletion with disposition review	Records Management, Compliance
Compliance Manager (4 assessments)	Maps controls to PIPEDA, PHIPA, AI Baseline, Data Protection Baseline	Compliance, Audit
AI Label Advisor (Power Automate + Azure OpenAI)	Recommends and applies labels to unlabeled files using AI with human approval	Automation, AI Governance
Copilot DLP controls	Prevents Copilot from processing or surfacing regulated data	AI Security, Copilot Governance
Defender XDR + Sentinel integration	Surfaces DLP and IRM alerts in the unified security operations platform	SecOps, SOC

15. Production Considerations

Several decisions in this lab were made differently than they would be in production. These differences are documented here because understanding the tradeoffs is part of the value of running a ***lab***.

Lab decision	Production approach
Auto-labeling set to Enable mode immediately	Run simulation for 2 weeks first to validate match accuracy and avoid overwriting labels on existing content
Encryption rights limited to one account	Use security groups so multiple authorized users can access encrypted content without individual permission grants
AI Label Advisor sends metadata to OpenAI with no redaction	Add a redaction step to strip actual SIN and bank account values before sending content to the model
DLP policies in full block mode from day one	Start in audit mode, review matches for 2-4 weeks to identify false positives, then enable blocking in phases
Single Copilot license for testing	In production, run a phased rollout starting with a pilot group on sites that passed the DSPM oversharing assessment